

M1 — Identity, Onboarding & Account

Module Specification

Trading Journal App · v1.0 · July 2026 · Status: ready to break into tickets

Field	Value
Module ID	M1
Track / owner	Data In track — one owner, end to end
Depends on	M0 Foundation & Shared Contracts (data model, design system, error contract)
Blocks	Everything. No other module can identify a user until M1 exists.
Scope in	Sign-up, sign-in, email verification, password reset, sessions, onboarding, profile, security settings, consent, data export, account deletion
Scope out	Broker credentials (M2) · subscription and entitlements (M11) · notification delivery (M9) · trade data of any kind (M3)

Purpose

M1 answers one question for the entire product: who is this person, and what are they allowed to do? It also owns the first five minutes of the user experience — the part that decides whether someone ever reaches the journal at all.

Components in this specification

1. Stories
2. Data flow and schema
3. UI screens
4. Detailed description and business logic
5. Flowcharts
6. Test plan
7. Quality benchmarks
8. Security constraints
9. Error handling
10. External dependencies
11. Performance and scalability
12. Module relationships
13. Data policies (EU and US)
14. Documentation

1. Stories

Fourteen stories cover the module. Each becomes an epic or a ticket; the acceptance criteria are the testable conditions, not restatements of the story.

ID	Story	Acceptance criteria	Pri
US-01	As a new trader, I want to create an account with email and password so that I can start journaling.	Valid email + password ≥ 10 chars creates an account in pending_verification. Terms consent required. Duplicate email is rejected with a clear message.	Must
US-02	As a new trader, I want to sign up or in with Google so that I can skip password setup.	Google account creates a verified account. If the email already exists as a password account, the identities are linked after ownership is proven.	Must
US-03	As a new user, I want to verify my email so that my account is secure and recoverable.	Link valid 24 h, single use. Resend throttled to 60 s / max 5 per day. Verified accounts proceed to setup.	Must
US-04	As a returning trader, I want to sign in so that I can reach my journal.	Correct credentials create a session. Wrong credentials show one generic error. 5 failures in 15 min triggers logout.	Must
US-05	As a trader who forgot my password, I want to reset it so that I regain access.	Reset link valid 60 min, single use. Identical confirmation shown whether or not the account exists. All sessions revoked on success.	Must
US-06	As a first-time visitor, I want a short intro so that I understand the product before signing up.	3 skippable slides. Shown once. Never shown to a user who has completed it.	Should
US-07	As a new user, I want to set my timezone so that my trades are grouped into the right sessions.	Timezone pre-filled from the browser and always stored non-null, even when skipped. Change re-labels existing trades.	Must
US-08	As a user, I want to edit my profile so that my details stay correct.	Name, timezone and currency save immediately. Email change requires confirmation on the new address and notifies the old one.	Must
US-09	As a security-conscious user, I want to change my password so that I control access.	Current password required. On success all other sessions are revoked and a notification email is sent.	Must
US-10	As a user, I want to see and revoke active sessions so that I can shut out anyone else.	List shows device, approximate location, last active. Revoking ends that session within 60 s. Current session cannot be revoked from the list.	Should
US-11	As a user, I want to download my data so that I can keep or move it.	Export includes profile, trades, plans, strategies, journal entries. Machine-readable JSON + CSV. Link expires after 7 days.	Must
US-12	As a user, I want to delete my account so that my data is removed.	Type-to-confirm required. Account locked immediately, broker connections revoked at once, permanent erasure after 30 days, restorable in that window.	Must
US-13	As a user, I want to control what emails I	Separate toggles per purpose. Marketing consent is	Must

ID	Story	Acceptance criteria	Pri
	receive so that I am not spammed.	never bundled with terms. Each change writes a timestamped consent record.	
US-14	As a user, I want to stay signed in so that I am not re-authenticating constantly.	Access token 15 min, refresh 30 days when "keep me signed in" is checked, otherwise session-only. Silent refresh while active.	Should

Ticket-splitting note

US-01 through US-05 form the smallest shippable slice — a person can create an account, prove it is theirs, and get back in. Build those first and demo them before touching anything else.

2. Data flow and schema

Nine entities. M1 is the sole owner of every one of them: no other module writes to these tables, and other modules reference a user only by user_id.

Entity	Purpose	Key fields
User	The person. One row per human; the canonical identity other modules reference.	id · email · email_verified_at · display_name · timezone · display_currency · status · created_at · deleted_at
AuthIdentity	A way of proving you are that user. One user can have several.	id · user_id · provider (password google) · provider_user_id · password_hash · last_used_at
Session	An active sign-in on one device.	id · user_id · refresh_token_hash · device · ip · approx_location · created_at · last_seen_at · revoked_at
VerificationToken	Single-use email verification link.	id · user_id · token_hash · email · expires_at (24 h) · consumed_at
PasswordResetToken	Single-use password reset link.	id · user_id · token_hash · expires_at (60 min) · consumed_at
OnboardingProgress	What the user has completed, so flows are never repeated.	user_id · intro_seen · setup_completed_at · platform_hint
ConsentRecord	Evidence of consent given or withdrawn. Append-only.	id · user_id · purpose · granted (bool) · source · created_at
DataRequest	An export or deletion request and its progress.	id · user_id · type (export delete) · status · requested_at · completed_at · expires_at
AuditEvent	Security-relevant history for investigation and compliance.	id · user_id · event_type · ip · user_agent · metadata · created_at

2.1 How data moves

Sign-up. The screen posts email, password and consent. M1 creates a User (status pending_verification), an AuthIdentity of type password, a ConsentRecord per checkbox, and a VerificationToken. It then asks M9 to

send the verification email and emits `user.created`. Nothing else in the product reacts until the account is verified.

Sign-in. Credentials are checked against the `AuthIdentity`, a `Session` is created, and an access + refresh token pair is returned. Every attempt — successful or not — writes an `AuditEvent`.

Onboarding. First-run setup writes timezone and display currency onto the `User`, sets `OnboardingProgress`, and emits `user.onboarded`. This is the moment M3 gains a usable timezone.

Deletion. A `DataRequest` of type `delete` is created, the `User` moves to `pending_deletion`, broker connections are revoked immediately through M2, and `user.deletion_requested` is emitted. After 30 days a job performs the erasure and emits `user.deleted`, which every other module must honour for its own data.

The one rule that keeps this clean

M1 never reads or writes another module's data, and no other module writes M1's. Cross-module effects happen through events, never through shared tables.

3. UI screens

Ten screens, all built as working responsive mockups in **M1_UI_Mockups.html** — open it in any browser. Each screen can be switched between its states and between mobile and desktop widths, so the build target is unambiguous.

ID	Screen	States built
M1-S01	Welcome & intro swipes	Slide 1 · Slide 2 · Slide 3
M1-S02	Create account	Default · Error (duplicate / weak password) · Loading
M1-S03	Sign in	Default · Bad credentials · Locked out · Loading
M1-S04	Verify email	Link sent · Resending · Expired · Verified
M1-S05	Reset password	Request · Sent · Set new · Invalid link
M1-S06	First-run setup (timezone)	Default · Saving · Error
M1-S07	Profile & account	Default · Saving · Saved
M1-S08	Security & sessions	Default · Single session (empty) · Revoking
M1-S09	Privacy & data	Default · Preparing export · Export ready
M1-S10	Delete account	Confirm · Armed · Scheduled

3.1 Rules that apply to every screen

- Every screen implements all its states. A screen without a designed empty, loading and error state is not done.
- All copy is sentence case, active voice, and never blames the user. Errors say what happened and what to do next.
- Nothing is lost on failure: form values survive an error, always.
- Keyboard-navigable end to end, with visible focus. Contrast at least 4.5:1.

- Responsive from 375 px to desktop. Both are first-class, neither is an afterthought.
- Green and red are **reserved** for profit and loss everywhere in this product. Primary actions use blue so a button is never mistaken for a P&L signal.

4. Detailed description and business logic

The rules below are the module's real content. Where a rule looks unusually strict, the reasoning is stated — those are the ones that get quietly dropped otherwise.

4.1 Registration and identity

Rule	Decision
Minimum age	18+. Trading context makes this stricter than the GDPR default of 16 and avoids minors' data entirely.
Password policy	Minimum 10 characters. Checked against a known-breached password list. No forced rotation, no composition rules — length and uniqueness beat complexity theatre.
Duplicate email at sign-up	Rejected with a clear message. Sign-up necessarily reveals that an address exists; this is mitigated by rate limiting and bot protection rather than vague copy that would confuse legitimate users.
Sign-in errors	Always one generic message, with equalised response timing. Sign-in must not become an account-enumeration oracle.
Google + password on one email	Identities are linked to a single User only after the user proves ownership of the existing account. Silent auto-linking is an account-takeover vector and is not permitted.
Lockout	5 failed attempts in 15 minutes locks sign-in for 15 minutes, with a countdown and a reset shortcut. Lockout is per account and per IP.

4.2 Sessions and tokens

Rule	Decision
Access token	15 minutes. Short by design; refreshed silently while the user is active.
Refresh token	30 days with "keep me signed in", otherwise session-only. Rotated on every use; reuse of a rotated token revokes the whole family as a theft signal.
Password change or reset	Revokes every other session immediately. The user keeps only the session where the change was made.
Revocation propagation	A revoked session stops working within 60 seconds at the latest.
Logout	Clears local tokens and revokes the refresh token server-side. Local-only logout is not sufficient.

4.3 Timezone

This is the highest-consequence field in M1. Session detection in M3 depends entirely on it, and a wrong value silently corrupts every session statistic the trader ever sees — without any visible error.

Rule	Decision
Default value	Pre-filled from the browser and always stored, never null — even when the user skips setup. M3 must never receive an empty timezone.
Storage	IANA identifier (e.g. Asia/Kolkata), never a fixed UTC offset, so daylight-saving changes are handled correctly.
On change	Session labels on existing trades are recalculated by M3. The user is warned before saving, because their historical session statistics will shift.
Trade timestamps	Always stored in UTC. Timezone is a display and bucketing concern only — it never alters the stored instant.

4.4 Account lifecycle

State	Meaning and transitions
pending_verification	Created but email unconfirmed. Can sign in but is held at the verification wall. Auto-purged if unverified for 30 days.
active	Normal state. Full access.
suspended	Administrative hold (abuse, payment dispute). Sign-in blocked with an explanatory message. Reversible by an admin only.
pending_deletion	User requested deletion. Access blocked, broker connections revoked immediately, data retained for 30 days. The user can restore by signing in.
deleted	Personal data erased or anonymised. Legally required financial records are retained separately, unlinked from the identity.

5. Flowcharts

Three diagrams: how an account is created, how a returning user gets in, and the states an account can occupy. Each is followed by the reasoning behind its branches.

5.1 Sign-up and onboarding



Figure 1 — new user from first open to a ready account.

Reading it. The single decision is whether the user chose Google. That one branch matters because a Google account arrives already verified: the provider has proven the address, so forcing our own verification email would be friction with no security benefit. The email path costs two extra steps — create, then verify — and that gap is exactly where sign-up funnels leak, which is why the verification screen is designed to be actionable rather than a dead end.

Why both paths converge before onboarding. Intro swipes and timezone setup are identical regardless of how the account was created, so they sit after the merge. Timezone is deliberately the last step before entry: it is the one value the rest of the product cannot work correctly without.

5.2 Sign-in

Figure 2 — returning user, including failure and recovery branches.

Reading it. Two gates in sequence. The first asks whether the credentials are right; failure loops back with a deliberately generic message and an attempt counter, and after five failures within fifteen minutes the account is locked with a countdown. The second gate asks whether the email was ever verified — an unverified user does authenticate successfully, but lands on the verification wall instead of the dashboard.

The recovery path on the right is the important detail. A locked-out user must always have a way forward, so the reset route is offered from inside the failure state rather than hidden. Resetting a password revokes every existing session, on the assumption that a forgotten password may equally be a stolen one.

5.3 Account lifecycle

Figure 3 — the states an account can be in, and the transitions between them.

Reading it. Accounts move left to right, with one deliberate exception: the dashed line back from pending deletion to active. That thirty-day window is what makes deletion safe to offer — the user gets a real, immediate stop to processing, while still being protected from a decision made in frustration after a bad trading day.

Suspended sits off the main line because it is administrative rather than user-driven, and it is fully reversible. Deleted is the only terminal state: after erasure there is nothing left to restore, which is precisely why the grace period exists in front of it.

6. Test plan

Auth code fails in ways that are invisible until they are exploited, so the security layer here is not optional.

Layer	What it covers	Key cases
Unit	Pure logic with no I/O.	Password validation · token expiry maths · timezone normalisation · lockout counter · consent record writing
Integration	The module against its own contract and store.	Full sign-up writes User + AuthIdentity + ConsentRecord · token single-use enforcement · session revocation cascade · export assembles all entities
Contract	What M1 promises other modules.	user.created / user.onboarded / user.deleted events fire with the agreed shape · identity lookup returns timezone for M3
End-to-end	Real user journeys through the UI.	Sign up → verify → setup → app · Google sign-up → app · forgot password → reset → sign in · delete → restore within grace
Security	Abuse and attack paths.	Enumeration via sign-in and reset · brute force triggers lockout · expired and reused tokens rejected · refresh-token reuse revokes family · no secrets in logs
Accessibility	Usable without a mouse or sight.	Keyboard-only sign-up · visible focus on every control · labels announced · error text linked to its field · contrast ≥ 4.5:1

6.1 Manual QA checklist

#	Manual QA checklist item
1	Every screen renders correctly at 375 px and at 1440 px.
2	Every state in the mockup (loading, error, empty, success) is reachable in the real build.
3	Refreshing mid-flow does not lose entered data or strand the user.
4	Verification and reset emails arrive and their links work on mobile.
5	Back-button behaviour is sane at every step, including after sign-out.
6	Timezone auto-detect is correct in at least three zones (IST, GMT, EST).
7	Signing out on one device ends the session on that device only.
8	Deletion revokes broker connections immediately, not after the grace period.
9	Export downloads, opens, and contains all promised entities.
10	No credential, token, or password appears in any log or error message.

6.2 Test data

- Seeded users in every state: pending_verification, active, suspended, pending_deletion, and a Google-linked account.
- Users in at least three timezones (IST, GMT, EST) to catch offset and daylight-saving assumptions.
- Expired and already-consumed tokens, kept permanently in the seed so these paths are always testable.
- An account with enough history to make an export non-trivial.

7. Quality benchmarks

Numbers, not adjectives. Anything unmeasurable is not a benchmark.

Metric	Target	How it is measured
Sign-in response	p95 under 400 ms	Server timing, excluding network
Sign-up completion	p95 under 800 ms	Includes hashing; hash cost tuned to ~250 ms
Verification email delivery	95% within 30 s	Provider delivery webhook
Session validation	p99 under 50 ms	Called on nearly every request; must be cached
Data export generation	95% within 1 hour, 100% within 30 days	Job completion time vs request time
Sign-up completion rate	≥ 70% from start to verified	Funnel analytics
Onboarding drop-off	≤ 15% abandon at first-run setup	Funnel analytics
Timezone accuracy	≥ 98% correct without manual change	Share of users who never edit the detected value
Availability	99.9% monthly for auth endpoints	Uptime monitor; auth down means the whole app is down

Metric	Target	How it is measured
Accessibility	WCAG 2.1 AA on all 10 screens	Automated scan plus keyboard-only pass

Why the availability target is strict

Auth is the front door. If M1 is down, the product is down regardless of how healthy every other module is — so its uptime target is the highest in the system.

8. Security constraints

M1 holds credentials and is the gate in front of a user's complete financial history. Everything below is a requirement, not a recommendation.

Area	Constraint
Password storage	Memory-hard hashing (Argon2id preferred, bcrypt acceptable) with per-user salt and a tuned cost factor. Plaintext passwords are never stored, logged, or emailed.
Token storage	Verification, reset and refresh tokens are stored hashed. A database leak must not yield usable tokens.
Transport	HTTPS everywhere with HSTS. Cookies are Secure, HttpOnly and SameSite. No credential ever travels in a URL query string.
Rate limiting	Per IP and per account on sign-in, sign-up, reset request, and resend. Bot protection on public forms.
Enumeration	Sign-in and password reset must not reveal whether an account exists, in either copy or response timing.
OAuth	Authorization Code flow with PKCE. State parameter validated. Redirect URIs allow-listed exactly, no wildcards.
Session hygiene	Refresh-token rotation with reuse detection. Full revocation on password change, reset, and deletion request.
Logging	Never log passwords, tokens, or full session identifiers. Emails are masked in application logs.
Audit trail	Sign-in, sign-out, password change, email change, session revocation, export, and deletion are all recorded as AuditEvents.
Admin access	No admin can read a password. Impersonation, if it exists at all, is explicitly logged and time-boxed.
2FA readiness	The schema and the security screen accommodate TOTP from day one, even though the flow ships later.

9. Error handling

Every error has a code for logs, a defined system behaviour, and copy the user actually sees. Copy is written here, not improvised during the build.

Code	Scenario	System behaviour	What the user sees
AUTH-001	Wrong email or password	Attempt counted; timing equalised	"Email or password is incorrect."
AUTH-002	Account locked	Sign-in blocked for 15 min	"Too many attempts. Try again in mm:ss,

Code	Scenario	System behaviour	What the user sees
			or reset your password.”
AUTH-003	Email not verified	Session issued but gated	Verification wall with a resend button
AUTH-004	Account suspended	Sign-in refused	“This account is on hold. Contact support.”
AUTH-005	Account pending deletion	Offer restore instead of refusing	“Deletion is scheduled for {date}. Restore your account?”
REG-001	Email already registered	No new account created	“That email is already registered. Sign in instead.”
REG-002	Password too weak or breached	Rejected before hashing	“Too short — use at least 10 characters.” / “This password has appeared in a breach.”
REG-003	Terms not accepted	Blocked client and server side	Inline error on the checkbox
TOK-001	Verification link expired	Token rejected	Expired screen with “Send a new link”
TOK-002	Token already used	Rejected, treated as expired	Same expired screen — no distinction is drawn
TOK-003	Reset token invalid	Rejected	“This link is no longer valid.”
OAU-001	Google returns an error or is cancelled	No partial account created	“Google sign-in didn’t complete. Try again or use email.”
OAU-002	Google email matches an existing password account	Linking requires ownership proof	“This email already has an account. Sign in with your password to link Google.”
SYS-001	Email provider unavailable	Queue and retry with backoff; account still created	“Account created. Your verification email may take a few minutes.”
SYS-002	Save fails (network or server)	No data lost; form values preserved	“Couldn’t save. Check your connection and try again.”
DAT-001	Export generation fails	Retried; request stays open	“We hit a problem preparing your export. We’re retrying.”

The rule behind the vague messages

AUTH-001 and TOK-002 are deliberately unspecific. Distinguishing “no such account” from “wrong password”, or “used” from “expired”, hands an attacker free information. The user loses nothing — their next action is identical either way.

10. External dependencies

Every dependency needs a defined failure mode. A third party being down must degrade the module, never break it.

Dependency	Used for	If it fails	Fallback
Google OAuth	Social sign-up and sign-in	Users cannot use Google	Email + password path stays fully functional; surface a clear notice
Transactional email provider	Verification, reset, security notices	Users cannot verify or reset	Queue with retry and backoff; alert on-call; account creation still succeeds
Bot protection / CAPTCHA	Sign-up and reset abuse control	Forms open to automated abuse	Fall back to stricter rate limiting
Breached-password list	Rejecting known-compromised passwords	Check unavailable	Fail open: allow the password but log it; never block sign-up on this
IP geolocation	Approximate session location	Location missing	Show “Unknown location”; never treat it as authoritative
M9 Notifications	Delivery of all email and push	Messages undelivered	M1 owns the intent, M9 owns delivery and retries
Object storage	Holding generated export files	Exports cannot be delivered	Request stays queued; user is told it is still in progress

Fail open or fail closed

Security checks fail closed — if we cannot verify a token, access is refused. Convenience checks fail open — if the breached-password service is unreachable, sign-up still works. Confusing the two either locks out every user or quietly disables a control.

11. Performance and scalability

Concern	Position
Scale assumption for v1	Up to 50,000 registered users and 5,000 daily sign-ins. Nothing in M1 should need re-architecting below that.
Hottest path	Session validation, called on nearly every request in the product. It must be cached and must never require a full database read on the common path.
Deliberate slow path	Password hashing is intentionally expensive (~250 ms). It is CPU-bound, so sign-in throughput is bounded by CPU, not the database.
Email is asynchronous	Verification and notification emails are queued, never sent inline. A slow provider must never slow down sign-up.
Exports are asynchronous	Generated by a background job with progress surfaced in the UI. Large accounts must not block a web request.
What breaks first	The token/session store under sign-in spikes, followed by hashing CPU. Both are horizontally scalable; plan for that shape rather than vertical growth.
Growth triggers	Revisit design at 250k users, sustained sign-in above 50/s, or export generation exceeding 5 minutes at p95.

12. Module relationships

This is the contract surface. Once agreed, other modules can build against it with mocks while M1 is still being written.

Direction	Module	What crosses the boundary
Exposes	All modules	Authenticated user identity: user_id, status, and entitlement-relevant flags.
Exposes	M3 Trade Core	User timezone — required for session detection. M3 must never compute sessions without it.
Exposes	M9 Notifications	Verified email address and per-purpose consent state, so M9 knows what it is allowed to send.
Exposes	M11 Billing	A stable user identity to attach a subscription to.
Exposes	M2 Broker Integration	A platform hint captured during setup, used to offer the right connection first.
Consumes	M9 Notifications	Delivery of verification, reset, and security emails. M1 decides what to send; M9 sends it.
Consumes	M0 Foundation	Shared data model, design system, and error contract.
Emits	—	user.created · user.verified · user.onboarded · user.updated · user.deletion_requested · user.deleted
Triggers	M2, M3, M5, M7, M10	On user.deleted, every module must erase or anonymise its own data for that user. M1 orchestrates but does not reach into other modules' stores.

The dependency to watch

M3 cannot detect trading sessions without a timezone from M1. Agree that field's name, format and guarantees in M0 — it is the single most consequential handoff in the early build.

13. Data policies (EU and US)

M1 holds the account data and therefore carries most of the product's privacy obligations. Building to these rules now is far cheaper than retrofitting them.

13.1 What we hold and why

Data	Classification	Lawful basis (GDPR)
Email, name, password hash	Personal data; credentials are sensitive PI under CPRA	Contract — needed to provide the service
Timezone, display currency	Personal data (low sensitivity)	Contract
IP address, device, approximate location	Personal data	Legitimate interests — security and fraud prevention

Data	Classification	Lawful basis (GDPR)
Session and audit records	Personal data	Legitimate interests — security; legal obligation where applicable
Marketing preferences	Personal data	Consent — freely given, separately captured
Usage analytics	Personal data (pseudonymised)	Consent in the EU; legitimate interests elsewhere
Trading history (via other modules)	Personal data; commercially sensitive	Contract

13.2 GDPR (EU / UK)

Obligation	How M1 meets it
Lawful basis (Art. 6)	Documented per data type in the inventory above. Marketing is consent-based and never bundled with terms acceptance.
Consent quality (Art. 7)	Separate, unbundled, opt-in toggles. Withdrawal is as easy as granting — one toggle on S09. Every change is recorded with a timestamp and source.
Right of access (Art. 15)	Self-service export on S09, no support ticket required.
Rectification (Art. 16)	Profile is directly editable on S07.
Erasure (Art. 17)	Self-service deletion on S10. Erasure completes after a 30-day grace period, which is within “undue delay” while protecting users from mistakes.
Portability (Art. 20)	Export is machine-readable JSON and CSV, not a PDF.
Response time	One month, extendable by two for complex requests. Target is under one hour via automation.
Privacy by design (Art. 25)	Data minimisation: no phone number, no address, no date of birth beyond an 18+ attestation. We do not collect what we do not need.
Processor agreements (Art. 28)	A data processing agreement is required with every provider — email, analytics, hosting, LLM. No provider is used without one.
Records of processing (Art. 30)	The data inventory in this section is the seed of the formal register.
Breach notification (Art. 33/34)	Supervisory authority within 72 hours; affected users without undue delay where risk is high. The runbook names who declares a breach.
International transfers	Standard Contractual Clauses or an adequacy decision required for any processor outside the EEA. Provider regions must be recorded.

13.3 United States (CCPA / CPRA and state law)

Requirement	How M1 meets it
Applicability	CCPA/CPRA thresholds may not be met at launch, but M1 is built to comply from day one — retrofitting privacy is far more expensive.
Notice at collection	Purpose stated at the point of collection, not only in the policy. The sign-up screen carries the

Requirement	How M1 meets it
	terms and risk disclaimer inline.
Right to know / access	Same self-service export as GDPR access.
Right to delete	Same self-service deletion flow.
Right to correct	Profile editing on S07.
Sale or sharing	We do not sell or share personal information for cross-context behavioural advertising. This is stated plainly on S09, so no “Do Not Sell” link is required — but the position must be re-checked before adding any ad tooling.
Sensitive personal information	Account credentials are sensitive PI under CPRA. Use is limited to providing the service; no secondary use.
Response time	45 days, extendable by a further 45.
Opt-out preference signals	Global Privacy Control is honoured for analytics; required immediately if sharing ever begins.
State breach-notification laws	All 50 states require notification. The incident runbook must cover US notification alongside GDPR’s 72-hour rule.
Not a broker or adviser	The product journals a user’s own trades and gives no personalised investment advice, keeping it outside SEC/FINRA registration. The risk disclaimer at sign-up protects this position and must not be weakened by the AI coach’s copy in M7.

13.4 Retention schedule

Data	Retention	Reason
Account and profile	Life of account + 30-day grace	Service delivery; restore window
Access token	15 minutes	Minimise the blast radius of a leak
Refresh token	30 days, rotated on use	Balance convenience against risk
Verification token	24 hours	Short-lived by design
Password reset token	60 minutes	Short-lived by design
Session records	90 days after expiry	Security investigation
Audit and security logs	12 months	Investigation and compliance evidence
Consent records	3 years after withdrawal	Evidence that consent was validly obtained
Generated export files	7 days, then deleted automatically	A stale export is a standing breach risk
Backups	Maximum 35 days	Bounds the window in which deleted data can still exist
Deleted	Erased or anonymised at 30 days	Right to erasure

Data	Retention	Reason
accounts		
Legally required financial records	As required by law, unlinked from identity	Legal obligation overrides erasure

Two things not to get wrong

First: deletion must genuinely propagate. If M1 erases a user but M3 keeps their trades, the erasure is incomplete and the obligation is unmet — which is why `user.deleted` is a contract every module must honour. Second: the risk disclaimer is load-bearing. It is what keeps a journaling product from looking like regulated investment advice, and its wording must stay consistent with whatever the AI coach says in M7.

14. Documentation

Documentation is part of the module, not an afterthought once the code works.

Deliverable	Contents
Module README	What M1 does, how to run it locally, environment variables, how to seed test users.
Contract / API reference	Every endpoint and event M1 exposes, generated from the contract agreed in M0.
Decision log (ADRs)	Initial entries: why 18+; why generic sign-in errors; why 30-day deletion grace; why timezone is mandatory and non-null; why Google linking requires ownership proof; why 2FA is scaffolded but deferred.
Runbook	What to do when email delivery fails, when sign-in error rates spike, when a breach is suspected (including the 72-hour clock), and how to restore an account mid-grace.
Data inventory & retention register	The tables in section 13, maintained as living documents rather than a one-off.
User-facing help	Articles: verifying your email · resetting your password · why timezone matters · exporting your data · deleting your account.
UI mockups	M1_UI_Mockups.html — all 10 screens with every state, responsive at mobile and desktop widths.

14.1 Definition of done

M1 is done when all of the following are true:

- Every story meets its acceptance criteria.
- The contract in section 12 is published, and at least one other module has built against it — even if only with mocks.
- All ten screens are built with every state, responsive at 375 px and desktop.
- Every error in section 9 is reachable and shows its written copy.

- Security constraints in section 8 are implemented and tested, including the enumeration and brute-force cases.
- Export and deletion work end to end, and deletion propagates through the event.
- Benchmarks in section 7 are measured, not assumed.
- README, ADRs and runbook are written; the data inventory is filled in.
- Demoed to the other two owners, with the contract walked through explicitly.

End of M1 specification — v1.0. Sample module: the same 14-component structure applies to M2-M12.